

**SIMATS ENGINEERING
ASSESSMENT TOOL 3**

COURSE CODE: CSA5115

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS:

20

Annexure A

MOCK INTERVIEW

Code of Conduct:

I Nissanki Sri Venkata Lakshmi Kavya(192373036) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

N.S.V.L.Kavya

Annexure A

MOCK INTERVIEW

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.

SSL is an older security protocol with several known vulnerabilities. Older SSL versions support weak encryption algorithms and outdated cryptographic mechanisms. SSL 3.0 is vulnerable to attacks such as POODLE.

TLS is considered more secure because it provides stronger encryption, improved authentication, secure key-exchange mechanisms, and better protection against modern attacks. TLS 1.2 and TLS 1.3 are widely used in modern web systems.

Answer: TLS is preferred over SSL because it provides stronger and more modern security mechanisms and removes many weaknesses present in older SSL versions.

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

The TLS handshake starts when the client sends a **ClientHello** message containing supported TLS versions, cipher suites, and a random value. The server responds with a **ServerHello** and selects the security parameters.

The server then sends its digital certificate. The client validates the certificate to authenticate the server. Next, the client and server perform a secure key-exchange process, such as ECDHE.

Both sides independently derive the same shared session key. After the handshake is completed, this symmetric session key is used to encrypt and authenticate application data.

Answer: TLS uses authenticated key exchange to establish shared session keys securely, which are then used for fast encrypted communication.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

SSL and TLS both provide encryption, authentication, and data integrity, but TLS is the improved successor to SSL.

TLS provides stronger cryptographic algorithms, improved key exchange, stronger authentication, better integrity protection, and removal of outdated algorithms.

Answer: The major improvements in TLS include stronger encryption, secure key exchange, improved authentication, better integrity protection, and protection against known weaknesses in older SSL protocols.

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

Suppose a user connects to an online banking website, but an attacker performs a man-in-the-middle attack and presents a fraudulent certificate.

If the application does not properly validate the certificate, it may accept the attacker's server as legitimate. The attacker could then intercept or modify communication.

This could result in stolen usernames, passwords, session information, or financial data.

Answer: Improper certificate validation can allow man-in-the-middle attacks, resulting in data theft, session hijacking, and modification of sensitive information.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

Digital certificates bind a server's identity to its public key. Certificates are issued and digitally signed by trusted Certificate Authorities (CAs).

During a TLS connection, the client verifies the certificate's issuer, validity period, certificate chain, and server identity.

If these checks are successful, the client can trust that it is communicating with the intended server.

Answer: Digital certificates provide server authentication by proving that the public key belongs to the legitimate server.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

SET stands for **Secure Electronic Transaction**. It was designed specifically to protect online credit card transactions.

SET uses encryption, digital certificates, digital signatures, and public-key cryptography. It authenticates the participants and protects payment information from unauthorized access.

It also separates order information from payment information, reducing the merchant's exposure to sensitive card details.

Answer: SET protects credit card transactions by providing confidentiality, authentication, integrity, and secure payment processing using cryptographic techniques.

7. Evaluate the limitations of the SET protocol in current online payment systems.

The major limitations of SET are its high implementation complexity, certificate-management requirements, limited modern browser support, and high deployment cost.

SET was also not widely adopted compared with simpler technologies such as TLS and modern payment gateways.

Answer: SET is less practical today because it is complex, has limited modern support, and has been largely replaced by TLS-based security and secure payment gateways.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

SET is specifically designed for electronic payments and provides strong payment-specific security. However, it requires complex certificate and infrastructure management.

TLS provides secure communication between the browser and server and is widely supported by modern browsers. It is easier to deploy and scales well for large e-commerce systems.

Answer: TLS-based payment security is more practical today because it provides strong communication security, excellent browser compatibility, lower complexity, and easy integration with modern payment gateways.

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

Suppose an employee downloads a fake PDF application from an untrusted website. The application appears legitimate but secretly installs malware and steals information.

This is a **Trojan** because the malware disguises itself as legitimate software and depends on the user executing it.

Answer: A virus attaches itself to files, a worm automatically replicates and spreads across networks, while a Trojan disguises itself as legitimate software. The given scenario is a Trojan attack.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

A worm spreads automatically by exploiting vulnerable systems and network services.

The organization should immediately isolate infected computers, block malicious network traffic, patch vulnerable systems, update endpoint security software, and disable unnecessary services.

Network segmentation, IDS/IPS monitoring, strong access controls, and regular backups should also be used.

Answer: The best response is to quickly detect and isolate infected systems, block the worm's communication, patch vulnerabilities, and monitor the network to prevent further spread.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

Suppose an employee installs a fake accounting application containing a Trojan. The Trojan secretly records passwords and allows an attacker to access company files.

This affects **confidentiality** because sensitive information can be stolen. It affects **integrity** because attackers may modify files, configurations, or transactions.

Answer: Trojans can compromise both confidentiality and integrity by secretly stealing information and allowing attackers to modify or control system resources.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

Virus: A virus attaches itself to legitimate files and spreads when the infected file is executed.

Worm: A worm is self-replicating and can automatically spread from one computer to another through network vulnerabilities.

Trojan: A Trojan disguises itself as legitimate software and usually requires the user to install or execute it.

Answer: Viruses mainly infect files, worms rapidly spread across networks, and Trojans trick users into installing malicious software.

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

A packet-filtering firewall examines packets based on information such as source IP, destination IP, port number, and protocol.

The firewall compares these values with predefined rules and either allows or blocks the packet.

Its limitations include limited application-level awareness, difficulty handling complex rules, and inability to understand the complete connection context in a basic stateless configuration.

Answer: Packet filtering provides basic network protection but is insufficient by itself for modern networks because it has limited visibility into application-level and sophisticated attacks.

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

Consider a company web server that must allow HTTPS traffic but should prevent public SSH access.

Example rules:

Source	Port	Protocol	Action
Any	443	TCP	Allow
Internal Network	22	TCP	Allow
Any	22	TCP	Block
Any	Any	Any	Block

Answer: HTTPS traffic is allowed for legitimate web users, while SSH is restricted to the internal network. All other unspecified traffic is blocked by default.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

A stateless firewall examines each packet independently without maintaining information about previous packets.

A stateful firewall maintains a connection-state table and determines whether traffic belongs to an established or legitimate connection.

Answer: Stateful firewalls are generally more effective because they understand connection context, provide better traffic control, and can automatically handle legitimate response traffic. However, they require more resources than basic stateless firewalls.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

The main firewall types include:

- **Packet-filtering firewall:** Filters traffic based on IP addresses, ports, and protocols.
- **Stateful firewall:** Tracks active connections.
- **Proxy firewall:** Acts as an intermediary between clients and servers.
- **NGFW:** Provides advanced application-aware filtering and threat prevention.
- **WAF:** Protects web applications from application-layer attacks.

Answer: A **Next-Generation Firewall (NGFW)** is generally the most suitable choice for an enterprise because it provides advanced traffic inspection, application awareness, access control, and threat-prevention capabilities.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

A signature-based IDS compares network activity with known attack patterns. It is effective at detecting known threats but may not detect new attacks.

An anomaly-based IDS first establishes a baseline of normal behavior. It then identifies significant deviations from that normal behavior.

Answer: Signature-based detection is effective for known attacks, while anomaly-based detection can identify previously unknown or unusual attacks. Combining both provides better detection coverage.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

An IDS monitors network traffic and identifies unusual patterns such as sudden traffic increases, excessive connection requests, or abnormal packet rates.

An IPS can automatically respond by blocking suspicious traffic, dropping malicious packets, and applying rate limits.

For large-scale DDoS attacks, IDS/IPS should be combined with upstream DDoS protection, traffic filtering, rate limiting, and scalable network infrastructure.

Answer: IDS detects DDoS activity while IPS can automatically block or limit malicious traffic. Together with dedicated DDoS protection, they help reduce the impact of attacks.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

IDS (Intrusion Detection System):

- Detects suspicious activity.
- Generates alerts.
- Records security events.
- Usually does not directly block traffic.

IPS (Intrusion Prevention System):

- Detects suspicious activity.
- Automatically blocks or drops malicious traffic.
- Can terminate suspicious connections.
- Works as an active security control.

Answer: IDS mainly provides detection and alerting, whereas IPS provides active detection and prevention.

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

False positives occur when legitimate activity is incorrectly identified as an attack.

To reduce them, the organization should:

1. Tune IDS rules regularly.

2. Establish accurate normal-activity baselines.
3. Use both signature-based and anomaly-based detection.
4. Whitelist verified legitimate activity.
5. Use contextual information such as user, device, and network behavior.
6. Keep attack signatures updated.
7. Prioritize alerts based on severity.
8. Continuously evaluate and retrain detection models where appropriate.

Answer: Regular rule tuning, accurate baselines, contextual analysis, and combining multiple detection techniques can reduce false positives while maintaining high detection accuracy.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge
Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problem-solving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides well-structured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively

Confidence	15	Displays high confidence, positive attitude, and professional behavior throughout	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism
------------	----	---	---	---------------------------------------	--------------------------------------